Ciberseguridad: programa de transición cuántica

Resumen ejecutivo

El NIST sitúa la criptografía poscuántica como una respuesta a la amenaza futura de ordenadores cuánticos capaces de comprometer sistemas criptográficos utilizados actualmente. Su programa publicó los tres estándares principales en 2024 y recomienda que las organizaciones comiencen a aplicarlos para preparar la migración. La fuente describe un horizonte tecnológico incierto; no proporciona una fecha única a partir de la cual toda la infraestructura empresarial vaya a ser vulnerable. [nist-pqc]

Análisis. Para la dirección, la decisión práctica consiste en preparar una transición controlada de las dependencias criptográficas. El alcance no se limita a sustituir una biblioteca: incluye cómo se protegen los datos, qué identidades se consideran fiables y qué servicios dependen de certificados o firmas. La prioridad debe responder al tiempo durante el que la información necesita mantenerse confidencial y a la dificultad de modificar los sistemas que la procesan. Un inventario incompleto impediría justificar el orden de intervención.

Recomendación. Iniciar un programa con responsables de seguridad, arquitectura, compras y continuidad. Su primer resultado debería ser un inventario contrastado con los propietarios de los servicios, acompañado de criterios para priorizar pruebas y dependencias. Antes de comprometer un presupuesto o un calendario, solicitar evidencia de compatibilidad a los proveedores y medir el comportamiento de una prueba representativa. Este informe propone decisiones y controles; no atribuye a la empresa un nivel de exposición que no se ha evaluado.

Recomendación. El patrocinio de este programa debería concretarse en decisiones observables: quién mantiene el inventario, quién acepta el riesgo de una excepción y qué evidencia permite cerrar un piloto. Seguridad puede definir criterios, pero los propietarios de los servicios deben confirmar sus dependencias y condiciones de recuperación. Compras debería incorporar las respuestas de los proveedores al registro del servicio correspondiente. La evaluación del avance necesita diferenciar componentes descubiertos, componentes ensayados y componentes aceptados para operación. Esta separación evita tratar la mera disponibilidad comercial de una tecnología como prueba de preparación de la organización. El entregable inicial propuesto es un mapa de dependencias con incertidumbres asignadas a un responsable, suficiente para elegir el siguiente ensayo sin anticipar resultados.

Qué cambia en los mecanismos de confianza

FIPS 203 especifica ML-KEM, un mecanismo de encapsulación de claves que permite establecer un secreto compartido a través de un canal público bajo determinadas condiciones. Ese secreto puede utilizarse posteriormente con algoritmos simétricos. FIPS 204 especifica ML-DSA para generar y verificar firmas digitales. FIPS 205 especifica SLH-DSA, una alternativa de firma basada en funciones hash. Encapsular claves y firmar mensajes son funciones distintas; seleccionar un mecanismo exige identificar qué función realiza cada componente. [nist-fips-203] [nist-fips-204] [nist-fips-205]

Análisis. La separación entre intercambio de claves y firmas ayuda a evitar una sustitución indiscriminada. Una aplicación puede depender de varios mecanismos a la vez: comunicación con otros servicios, autenticación de usuarios y validación de paquetes de software. Cambiar solo una de esas dependencias no acredita que el servicio completo esté preparado. También conviene distinguir la protección de información que viaja por la red de los procesos que validan la procedencia y la integridad de un documento o una actualización.

Recomendación. Documentar por servicio la finalidad de cada uso criptográfico, su propietario, la implementación utilizada y la dependencia externa que condiciona su sustitución. Registrar qué pruebas demostrarían compatibilidad y cuáles demostrarían una regresión. Las conclusiones de una prueba de laboratorio deben mantenerse separadas de la aceptación operativa y de cualquier afirmación de seguridad sobre el sistema completo.

Recomendación. Al revisar un servicio conviene recorrer el flujo completo: quién inicia la conexión, cómo se valida la identidad de la contraparte, dónde se conserva el material criptográfico y qué ocurre cuando una credencial caduca o debe revocarse. Después se pueden contrastar esos pasos con las interfaces que ofrece cada implementación candidata. Para un proceso de firma, el ensayo debería contemplar también cómo se conserva la evidencia y cómo la comprueba un tercero. Para el establecimiento de claves, debería incluir el comportamiento de clientes incompatibles y las condiciones de negociación. Estas preguntas describen un método de evaluación; sus respuestas dependen del sistema instalado y deben obtenerse mediante documentación y pruebas propias.

Implicaciones para datos y operaciones

Análisis. La primera dimensión de riesgo es la vida útil de la información. Un documento con obligaciones de confidencialidad prolongadas merece una evaluación distinta de un dato efímero. La organización debería identificar quién puede acceder a las copias, cómo se intercambian y qué garantías necesita conservar. Ese ejercicio no requiere inventar pérdidas económicas: requiere relacionar los datos con procesos concretos y con requisitos de conservación que ya existan en la organización.

Análisis. La segunda dimensión es la capacidad de cambio. Una dependencia administrada por un proveedor puede exigir una actualización contractual o una nueva versión. Un equipo antiguo puede necesitar una alternativa operativa antes de poder sustituirse. Conviene separar los obstáculos observados de los supuestos pendientes de validar. Que un producto anuncie soporte para un estándar no demuestra que la configuración instalada, sus integraciones y su procedimiento de recuperación puedan utilizarlo correctamente.

Recomendación. Añadir a la evaluación de proveedores preguntas verificables sobre implementaciones soportadas, interoperabilidad, mantenimiento y procedimientos de actualización. Pedir documentación técnica y resultados reproducibles, evitando aceptar expresiones comerciales como evidencia. Registrar las respuestas junto al servicio afectado y el responsable de validarlas. En sistemas críticos, ensayar el cambio en un entorno separado y acordar una forma de volver a la configuración anterior si aparecen fallos.

Recomendación. Para priorizar, conviene cruzar la sensibilidad y la duración de la confidencialidad con la dificultad de modificar cada dependencia. Un servicio fácil de actualizar puede servir de piloto aunque otro requiera una atención estratégica mayor. Los casos bloqueados por equipos o contratos antiguos necesitan una decisión explícita sobre medidas temporales y fecha de revisión, sustentada en evidencia del propietario. La continuidad también merece una prueba específica: poder volver a la configuración anterior no basta si se pierde acceso a datos o si la recuperación depende de una credencial que ya no funciona. Deben conservarse resultados de restauración y registrar qué participantes y sistemas quedaron fuera del ensayo.

Programa de transición propuesto

Recomendación. Empezar por descubrir y clasificar las dependencias. Contrastar el inventario con arquitectura, operación y propietarios del negocio; conservar evidencias que permitan resolver discrepancias. Seleccionar después un caso que combine relevancia para la organización y posibilidad de ensayo. El resultado esperado es una decisión informada sobre los siguientes pasos, acompañada de incertidumbres explícitas, y no una declaración general de que la empresa ya es resistente a amenazas cuánticas.

Recomendación. Diseñar pruebas que evalúen el establecimiento de conexiones, el uso de certificados, la verificación de firmas y la recuperación tras un fallo. Comparar los resultados con una línea de base registrada en el mismo entorno. Medir tiempos, consumo de recursos y errores sin fijar por adelantado mejoras que no se han observado. Revisar también los clientes y servicios que interactúan con el componente actualizado, porque la compatibilidad depende de ambos extremos.

Recomendación. Condicionar el avance a criterios de aceptación explícitos: responsables disponibles, evidencia de interoperabilidad, observabilidad suficiente y procedimiento de reversión ensayado. Mantener un registro de decisiones que explique por qué se prioriza cada dependencia. Ajustar la planificación cuando una prueba o una comunicación del proveedor aporte nueva información. Ningún plazo o importe de este programa debe interpretarse como comprometido: su estimación requiere el inventario y mediciones de la organización.

Recomendación. La aprobación del piloto debería producir un expediente breve con alcance, configuración probada, resultados, incidencias y decisión responsable. Si una prueba no cubre un cliente relevante, esa exclusión debe aparecer junto a la conclusión. La ampliación puede organizarse por grupos de dependencias compatibles, con criterios para detener cambios cuando aparezcan errores y con responsables de atenderlos. El seguimiento debería registrar versiones y configuraciones para poder repetir el ensayo cuando cambie un componente. Antes de declarar una fase cerrada, contrastar las evidencias con los criterios acordados y resolver las excepciones. Así se conserva una relación comprobable entre el trabajo realizado y la autorización para ampliar su uso.

Decisiones y seguimiento

Análisis. La dirección necesita visibilidad sobre las dependencias pendientes, las pruebas realizadas y las decisiones que requieren recursos. Un seguimiento útil debe enlazar cada conclusión con su evidencia y con el responsable de mantenerla. La cantidad de sistemas inventariados puede ser una señal de avance, pero por sí sola no acredita que estén preparados para una transición. Conviene revisar las excepciones y distinguir los bloqueos técnicos de las decisiones todavía pendientes.

Recomendación. Aprobar el inicio del inventario y seleccionar un piloto antes de fijar un despliegue general. Pedir a los responsables un informe de resultados que incluya fallos, límites y dudas abiertas. Revisar las publicaciones primarias durante la evolución del programa y comprobar las erratas aplicables antes de elegir una implementación. Las referencias siguientes corresponden a páginas realmente consultadas para este ensayo; no equivalen a una auditoría independiente de todos los sistemas ni de cada afirmación del informe.

Recomendación. En cada revisión del programa conviene resolver decisiones pendientes concretas: aceptar el resultado del piloto, ampliar su alcance, pedir evidencia adicional o mantener una dependencia en observación. Cada decisión debería señalar las condiciones que harían necesario revisarla. Una excepción necesita un propietario y un próximo punto de revisión; sin ambos puede desaparecer del seguimiento aunque el riesgo permanezca. La documentación debe conservar las incertidumbres relevantes y separar las recomendaciones del informe de las comprobaciones realizadas por la organización. Este enfoque permite actualizar el programa sin presentar como definitivo un diagnóstico que depende de sistemas todavía no inventariados.

Referencias consultadas

[nist-fips-203] FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard — NIST. https://csrc.nist.gov/pubs/fips/203/final (2026-10-13).

[nist-fips-204] FIPS 204: Module-Lattice-Based Digital Signature Standard — NIST. https://csrc.nist.gov/pubs/fips/204/final (2026-10-13).

[nist-fips-205] FIPS 205: Stateless Hash-Based Digital Signature Standard — NIST. https://csrc.nist.gov/pubs/fips/205/final (2026-10-13).

[nist-pqc] Post-Quantum Cryptography — NIST. https://csrc.nist.gov/projects/post-quantum-cryptography (2026-10-13).